

US001 – Login com E-mail e Senha

Estória de Usuário

PROJETO	Gestão de Atividades
CLIENTE	ITB
TEMA	Gestão de Tarefas
ÉPICO	EP03 – Cadastro de Tarefas
ESTÓRIA	US001 – Login com E-mail e Senha

RESUMO

Objetivo principal do usuário (ação, resultado, objetivo)

Permitir o acesso ao sistema por meio de autenticação com e-mail e senha, possibilitando que cada usuário acesse as funcionalidades de acordo com seu perfil de forma segura e controlada.

Pré-requisitos para a operação

- O usuário deve possuir cadastro ativo no sistema, realizado previamente por um Administrador.
- O usuário deve conhecer seu e-mail e senha cadastrados.
- O sistema deve estar disponível e acessível pelo navegador.

DETALHAMENTO

NARRATIVA

- Como usuário cadastrado no sistema (qualquer perfil);
- Quero realizar login com meu e-mail e senha;
- Para acessar as funcionalidades do sistema de acordo com as permissões do meu perfil.

CRITÉRIOS DE ACEITE

1. O processo deve ser iniciado por meio da tela de login, acessada diretamente pela URL do sistema. A tela de login deve ser a primeira tela exibida para usuários não autenticados.

2. A tela de login deve conter os seguintes campos e elementos:

Campo / Elemento	Especificação	Tipo	Regra de negócio
E-mail	Endereço de e-mail cadastrado. Campo obrigatório.	Texto (e-mail)	RN001
Senha	Senha do usuário. Campo obrigatório. Conteúdo mascarado.	Senha (oculto)	RN002
Lembrar acesso	Mantém a sessão ativa por 30 dias no dispositivo.	Checkbox (opcional)	RN003
Botão Entrar	Submete as credenciais para autenticação.	Botão primário	RN001, RN002
Link Esqueci minha senha	Redireciona para o fluxo de recuperação de senha.	Link	—

3. Ao acionar o botão "Entrar", o sistema deve validar as credenciais informadas:

- Credenciais válidas e usuário ativo: o sistema deve redirecionar o usuário para a tela de Dashboard;
- Credenciais inválidas (e-mail não encontrado ou senha incorreta): o sistema deve exibir mensagem de erro genérica, sem especificar qual campo está incorreto, conforme RN004;
- Usuário com situação Inativa: o sistema deve exibir mensagem informando que o acesso está bloqueado e orientar o usuário a contatar o administrador.

4. O sistema não deve permitir mais de 5 tentativas de login consecutivas com credenciais inválidas para o mesmo e-mail. Após atingir o limite, o acesso deve ser bloqueado

temporariamente por 15 minutos, conforme RN005.

5. Enquanto a autenticação está sendo processada, o botão "Entrar" deve ser desabilitado e exibir indicador de carregamento, evitando múltiplos envios simultâneos.
6. A tela de login não deve ser acessível para usuários já autenticados. Caso um usuário autenticado acesse a URL de login, deve ser redirecionado automaticamente para o Dashboard.
7. A senha deve ser exibida com caracteres mascarados. O campo deve disponibilizar ícone para alternar entre visualizar e ocultar o conteúdo.
8. Todas as informações exibidas devem seguir a regra de tipografia definida em RNG009.
9. O sistema deverá seguir o comportamento definido na regra CTG011 (Documento Padrão) sempre que houver ausência de preenchimento em campos obrigatórios.

REGRAS DE NEGÓCIOS ESPECÍFICAS

RN001 – E-mail obrigatório e formato válido

O campo E-mail é obrigatório. O sistema deve validar que o valor informado possui formato de endereço de e-mail válido (ex.: usuario@dominio.com) antes de submeter as credenciais. A validação deve ocorrer no frontend e ser reforçada no backend.

RN002 – Senha obrigatória

O campo Senha é obrigatório. O sistema não deve impor regras de formato na tela de login (ex.: comprimento mínimo), pois a validação de complexidade ocorre apenas no cadastro e na redefinição de senha.

RN003 – Lembrar acesso

Quando o checkbox Lembrar acesso estiver marcado, o token de sessão deve ter validade de 30 dias. Quando desmarcado, a sessão deve expirar ao fechar o navegador.

RN004 – Mensagem de erro genérica

Em caso de credenciais inválidas, o sistema deve exibir mensagem genérica (ex.: "E-mail ou senha incorretos. Verifique suas credenciais e tente novamente."), sem indicar qual campo está incorreto, para evitar enumeração de usuários cadastrados.

RN005 – Bloqueio por tentativas excessivas

Após 5 tentativas consecutivas de login com falha para o mesmo endereço de e-mail, o sistema deve bloquear temporariamente as tentativas de autenticação daquele e-mail por 15 minutos, exibindo mensagem informativa com o tempo restante para desbloqueio.

HABILITADORES TÉCNICOS

1. A autenticação deve ser implementada com transmissão segura de credenciais via HTTPS. Senhas nunca devem ser trafegadas ou armazenadas em texto plano.
 2. O token de sessão deve ser armazenado em cookie HttpOnly e Secure, com flag SameSite=Lax, para proteção contra ataques XSS e CSRF.
 3. O controle de tentativas de login deve ser realizado no backend, não no frontend, para evitar contornar a restrição por manipulação do cliente.
 4. Devem ser respeitados os padrões transversais do sistema (segurança, performance, tipografia, mensagens) citados no documento de regras gerais do sistema.
-

OBSERVAÇÕES GERAIS

- A tela de login deve ser responsiva, funcionando adequadamente em dispositivos desktop e tablet.
 - O fluxo de recuperação de senha, acessado pelo link "Esqueci minha senha", está descrito na história US-002 – Recuperação de Senha.
-

APROVAÇÕES

AÇÃO	RESPONSÁVEL	DATA
CRIADO POR	Joice Fonseca	15/05/2026
REVISADO POR	Tiago Martins	
REVISADO POR	Diego Souza	
APROVADOR POR	Rafael Capelari	